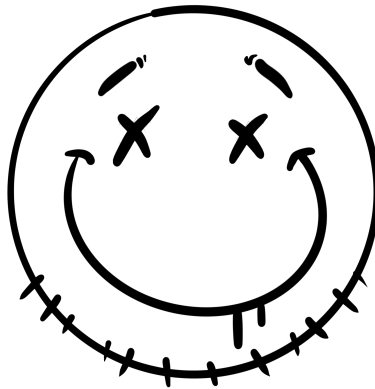




Firewall Configuration

Keith Schoen

CSEC 3755-001

Dr. Daniel Pittman

28 April 2026

Contents

1	Current State Analysis	1
1.1	Firewall Rules (iptables)	1
1.2	Identified Gaps and Weaknesses	1
2	Proposed Ruleset (By Section)	2
3	Testing Results	5

1 Current State Analysis

1.1 Firewall Rules (iptables)

INPUT chain - default policy ACCEPT:

- Rule 1: ICMP accepted from anywhere

FORWARD chain - default policy ACCEPT:

- Rule 1: All traffic forwarded eth0 → eth1
- Rule 2: All traffic forwarded eth1 → eth0

OUTPUT chain - default policy ACCEPT:

- No rules; completely open

1.2 Identified Gaps and Weaknesses

1. **Default ACCEPT policies** - All three chains accept everything by default. A secure firewall should default to DROP.
2. **Unrestricted forwarding** - All traffic passes freely between networks with no port or protocol filtering.
3. **No stateful inspection** - No rules tracking established/related connections.
4. **Management services exposed on all interfaces** - SSH and Webmin reachable from both the scan network and target network.
5. **Webmin on port 1000** - Web-based admin panel is a significant attack surface and should be restricted to a trusted management IP only.
6. **IIS 10.0 version disclosure** - Web server advertises its version in HTTP headers, aiding potential attackers in finding known vulnerabilities.

Service That Should Be Restricted Between Zones

- **SSH (port 22)** - Should only be reachable from the scan/management network, not from the target network.
- **Webmin (port 10000)** - Should be restricted to a single trusted IP, not exposed to any network broadly.
- **All forwarded traffic** - Should be whitelisted by specific port/protocol rather than allowing everything through.

2 Proposed Ruleset (By Section)

Chain 1: INPUT (traffic destined for the router itself)

Default policy: DROP

#	Name	Source	Destination	Port	Action	Justification
1	Allow loopback	127.0.0.1	127.0.0.1	any	Allow	Required for local system processes
2	Allow SSH management	eth0	Router	22	Allow	Administrators need remote access from scan-net side only
3	Allow ICMP	eth0	Router	ICMP	Allow	Network diagnostics and connectivity verification
4	Allow established/relate	Any	Router	Any	Allow	Stateful tracking for connections initiated by the router

#	Name	Source	Destination	Port	Action	Justification
5	Default deny INPUT	Any	Router	Any	Drop	Reject all traffic not explicitly permitted

Chain 2: FORWARD (traffic passing through the router between zones)

Default policy: DROP

#	Name	Source	Destination	Port	Action	Justification
1	Allow Established/Related	Any	Any	Any	Allow	Stateful tracking for all forwarded connections
2	Allow HTTP to target-net	eth0	eth1	80	Allow	Permits web access to IIS and patient portal services
3	Allow HTTPS to target-net	eth0	eth1	443	Allow	Encrypted web traffic to target services
4	Allow SSH to target-net	eth0	eth1	22	Allow	Administrative access to connected machines
5	Allow ICMP to target-net	eth0	eth1	ICMP	Allow	Network diagnostics and host discovery
6	Block target-net outbound	eth1	eth0	Any	Block	Compromised internal machines cannot initiate connections outbound
7	Default deny FORWARD	Any	Any	Any	Drop	No other cross-zone traffic is business justified

Chain 3: OUTPUT (traffic originating from the router itself)**Default policy: ACCEPT**

#	Name	Source	Destination	Port	Action	Justification
1	Allow all router output	Router	Any	Any	Allow	Router requires free communication for DNS, NTP, and management functions

3 Testing Results

To test the newly implemented firewall rules, the first step was to run a nmap scan from my Kali machine to see what is now visible through the firewall now that the rules have been updated.

- **What was blocked:** RDP (3389), SMB (445/139), MySQL (3306), FTP (21), SMTP (25), RPC (135), and WinRM (5985)
- **What still flows:** HTTP (80), and SSH (22) on both Ubuntu and Windows, and SSH on the router

```
(kali@kali)-[~]
$ nmap -sV 192.168.56.0/24
Starting Nmap 7.98 ( https://nmap.org ) at 2026-04-27 01:52 -0600
Nmap scan report for 192.168.56.1
Host is up (0.00025s latency).
All 1000 scanned ports on 192.168.56.1 are in ignored states.
Not shown: 1000 filtered tcp ports (no-response)
MAC Address: 0A:00:27:00:00:05 (Unknown)

Nmap scan report for 192.168.56.100
Host is up (0.00018s latency).
All 1000 scanned ports on 192.168.56.100 are in ignored states.
Not shown: 1000 closed tcp ports (reset)
MAC Address: 08:00:27:6A:D6:F7 (Oracle VirtualBox virtual NIC)

Nmap scan report for 192.168.56.102
Host is up (0.00029s latency).
Not shown: 993 closed tcp ports (reset)
PORT      STATE SERVICE      VERSION
21/tcp    open  ftp          vsftpd 2.0.8 or later
22/tcp    open  ssh          OpenSSH 9.6p1 Ubuntu 3ubuntu13.15 (Ubuntu Linux; prot
ocol 2.0)
25/tcp    open  smtp
80/tcp    open  http         Werkzeug httpd 2.2.0 (Python 3.9.25)
139/tcp   open  netbios-ssn Samba smbd 3.X - 4.X (workgroup: MEDTECH)
445/tcp   open  netbios-ssn Samba smbd 3.X - 4.X (workgroup: MEDTECH)
3306/tcp  open  mysql        MySQL 8.0.45
1 service unrecognized despite returning data. If you know the service/version,
please submit the following fingerprint at https://nmap.org/cgi-bin/submit.cgi?n
ew-service :
SF:Port25-TCP:V=7.98:I=7%D=4/27?Time=69EF15D4:P=x86_64-pc-linux-gnu&r(NULL
SF:.,41,"220\x20mail\medtech\local\x20MedTech\x20Solutions\x20SMTP\x20Ser
SF:ver\x20v1\4\x20Ready\r\n")%r(Hello,5C,"220\x20mail\medtech\local\x20
SF:MedTech\x20Solutions\x20SMTP\x20Server\x20v1\4\x20Ready\r\n501\x20Synt
SF:ax:\x20EHL0\x20hostname\r\n")%r(Help,91,"220\x20mail\medtech\local\x2
SF:0MedTech\x20Solutions\x20SMTP\x20Server\x20v1\4\x20Ready\r\n250\x20Sup
SF:ported\x20commands:\x20AUTH\x20DATA\x20EHL0\x20HELO\x20HELP\x20MAIL\x20
```

```

SF:NOOP\x20QUIT\x20RCPT\x20RSET\x20VRFY\r\n")%r(GenericLines,6F,"220\x20ma
SF:i\\.\medtech\.\local\x20MedTech\x20solutions\x20SMTP\x20Server\x20v1\.\4\
SF:20Ready\r\n500\x20Error:\x20bad\x20syntax\r\n500\x20Error:\x20bad\x20sy
SF:ntax\r\n")%r(GetRequest,81,"220\x20mail\.\medtech\.\local\x20MedTech\x20S
SF:olutions\x20SMTP\x20Server\x20v1\.\4\x20Ready\r\n500\x20Error:\x20comman
SF:d\x20"GET"\x20not\x20recognized\r\n500\x20Error:\x20bad\x20syntax\r\n
SF:");
MAC Address: 08:00:27:44:7F:09 (Oracle VirtualBox virtual NIC)
Service Info: Hosts: MedTech, 6C3D442378D3; OS: Linux; CPE: cpe:/o:linux:linux_k
ernel

Nmap scan report for 192.168.56.105
Host is up (0.00054s latency).
Not shown: 994 filtered tcp ports (no-response)
PORT      STATE SERVICE      VERSION
22/tcp    open  ssh          OpenSSH for Windows 9.5 (protocol 2.0)
80/tcp    open  http         Microsoft IIS httpd 10.0
135/tcp   open  msrpc        Microsoft Windows RPC
445/tcp   open  microsoft-ds?
3389/tcp  open  ms-wbt-server Microsoft Terminal Services
5985/tcp  open  http         Microsoft HTTPAPI httpd 2.0 (SSDP/UPnP)
MAC Address: 08:00:27:43:3D:E3 (Oracle VirtualBox virtual NIC)
Service Info: OS: Windows; CPE: cpe:/o:microsoft:windows

Nmap scan report for 192.168.56.106
Host is up (0.00037s latency).
Not shown: 998 closed tcp ports (reset)
PORT      STATE SERVICE      VERSION
22/tcp    open  ssh          OpenSSH 10.2 (protocol 2.0)
10000/tcp open  snet-sensor-mgmt?
1 service unrecognized despite returning data. If you know the service/version,
please submit the following fingerprint at https://nmap.org/cgi-bin/submit.cgi?n
ew-service :
SF-Port10000-TCP:V=7.98%I=7%D=4/27%Time=69EF15D4P=x86_64-pc-linux-gnu%r(G
SF:etRequest,15C8,"HTTP/1\.\0\x20200\x20Document\x20follows\r\nDate:\x20Mon
SF:,\x2027\x20Apr\x202026\x2000:14:32\x20GMT\r\nServer:\x20MiniServ\r\nCon
SF:nection:\x20close\r\nAuth-type:\x20auth-required=1\r\nSet-Cookie:\x20re
SF:direct=1;\x20path=/;\x20httpOnly\r\nSet-Cookie:\x20testing=1;\x20path=/
SF:;\x20httpOnly\r\nStrict-Transport-Security:\x20max-age=0;\r\nX-Frame-Op
SF:tions:\x20SAMEORIGIN\r\nContent-Security-Policy:\x20script-src\x20'self
SF:'\x20'unsafe-inline'\x20'unsafe-eval';\x20frame-src\x20'self';\x20child
SF:-src\x20'self'\r\nX-Content-Type-Options:\x20nosniff\r\nX-no-links:\x20
SF:1\r\nContent-type:\x20text/html;\x20Charset=UTF-8\r\n\r\n<!DOCTYPE\x20H
SF:TML>\n<html\x20data-bgs="\x20gainsboro"\x20class="\x20session_login">\n<hea
SF:d>\n<\x20meta\x20name="\x20color-scheme"\x20content="\x20only\x20light">\n\
SF:\x20<noscript>\x20<style>\x20html{[data-bgs="\x20gainsboro"]}\x20{\x20back
SF:ground-color:\x20#d6d6d6;\x20}\x20html{[data-bgs="\x20nightRider"]}\x20{
SF:\x20background-color:\x20#1a1c20;\x20}\x20html{[data-bgs="\x20nightRider"
SF:]\x20div{[data-noscript]}\x20{\x20color:\x20#979ba080;\x20}\x20html{[da
SF:ta-slider-fixed='1']}\x20{\x20margin-right:\x200;\x20!important;\x20}\x2
SF:0body\x20>\x20div{[data-noscript]}\x20~\x20")%r(HTTPOptions,1034,"HTTP/
SF:1\.\0\x20200\x20Document\x20follows\r\nDate:\x20Mon,\x2027\x20Apr\x2020
SF:26\x2000:14:39\x20GMT\r\nServer:\x20MiniServ\r\nConnection:\x20close\r\n
SF:Auth-type:\x20auth-required=1\r\nSet-Cookie:\x20redirect=1;\x20path=/;\
SF:\x20httpOnly\r\nSet-Cookie:\x20testing=1;\x20path=/;\x20httpOnly\r\nStri
SF:ct-Transport-Security:\x20max-age=0;\r\nX-Frame-Options:\x20SAMEORIGIN\
SF:r\nContent-Security-Policy:\x20script-src\x20'self'\x20'unsafe-inline'\
SF:\x20'unsafe-eval';\x20frame-src\x20'self';\x20child-src\x20'self'\r\nX-C
SF:ontent-Type-Options:\x20nosniff\r\nX-no-links:\x201\r\nContent-type:\x2
SF:0text/html;\x20Charset=UTF-8\r\n\r\n<!DOCTYPE\x20HTML>\n<html\x20data-b
SF:gs="\x20gainsboro"\x20class="\x20session_login">\n<head>\n<\x20meta\x20name
SF:=\x20"color-scheme"\x20content="\x20only\x20light">\n<\x20<noscript>\x20<sty
SF:le>\x20html{[data-bgs="\x20gainsboro"]}\x20{\x20background-color:\x20#d6
SF:d6;\x20}\x20html{[data-bgs="\x20nightRider"]}\x20{\x20background-color:\
SF:\x20#1a1c20;\x20}\x20html{[data-bgs="\x20nightRider"]}\x20div{[data-noscri
SF:pt]}\x20{\x20color:\x20#979ba080;\x20}\x20html{[data-slider-fixed='1']
SF:\x20{\x20margin-right:\x200;\x20!important;\x20}\x20body\x20>\x20div{[da
SF:ta-noscript]}\x20~\x20");
MAC Address: 08:00:27:FC:64:C3 (Oracle VirtualBox virtual NIC)

Nmap scan report for 192.168.56.103
Host is up (0.000062s latency).
Not shown: 999 filtered tcp ports (no-response)
PORT      STATE SERVICE      VERSION
22/tcp    open  ssh          OpenSSH 10.2p1 Debian 3 (protocol 2.0)
Service Info: OS: Linux; CPE: cpe:/o:linux:linux kernel

Service detection performed. Please report any incorrect results at https://nmap
.org/submit/ .
Nmap done: 256 IP addresses (6 hosts up) scanned in 142.11 seconds

```

Figure 01-04: Result of nmap scan of subnet before firewall rules were implemented


```
(kali@kali)~$ nmap -sV 10.0.1.0/24
Starting Nmap 7.98 ( https://nmap.org ) at 2026-04-28 20:31 -0600
Nmap scan report for 10.0.1.1
Host is up (0.00090s latency).
Not shown: 999 filtered tcp ports (no-response)
PORT      STATE SERVICE VERSION
22/tcp    open  ssh      OpenSSH 10.2 (protocol 2.0)

Nmap scan report for 10.0.1.10
Host is up (0.0017s latency).
Not shown: 998 filtered tcp ports (no-response)
PORT      STATE SERVICE VERSION
22/tcp    open  ssh      OpenSSH 9.6p1 Ubuntu 3ubuntu13.15 (Ubuntu Linux; protocol 2
.0)
80/tcp    open  http     Werkzeug httpd 2.2.0 (Python 3.9.25)
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel

Nmap scan report for 10.0.1.20
Host is up (0.0023s latency).
Not shown: 998 filtered tcp ports (no-response)
PORT      STATE SERVICE VERSION
22/tcp    open  ssh      OpenSSH for Windows 9.5 (protocol 2.0)
80/tcp    open  http     Microsoft IIS httpd 10.0
Service Info: OS: Windows; CPE: cpe:/o:microsoft:windows

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 256 IP addresses (3 hosts up) scanned in 25.20 seconds
```

Figure 05: Result of nmap scan after rules were implemented.

++report written with (minimal) help from Claude (Sonnet 4.6)++